

Esercizio 5: Anyrun

SANDBOX 1

Threat Intelligence: Campagna Infostealer Lumma/Vidar

1. Sintesi Esecutiva

Un eseguibile malevolo denominato **66bddfcb52736_vidar.exe** è stato analizzato e classificato come un'attività malevola, funzionando sia come "**Loader**" che come "**Stealer**" (ruba-informazioni). L'analisi indica la presenza simultanea di entrambe le famiglie di malware **Lumma** e **Vidar**. Il malware utilizza tecniche di **iniezione (process injection)**, nascondendosi in particolare all'interno dell'utilità **legittima** di Microsoft **RegAsm.exe**, per eludere il rilevamento. Una volta attivo, prende aggressivamente di mira un'ampia gamma di dati sensibili dell'utente, inclusi portafogli di criptovalute, credenziali del browser e token di sessione. La minaccia mostra un comportamento di **Comando e Controllo (C2)** complesso, utilizzando profili **Telegram** e **Steam** per instradare le sue comunicazioni, insieme a un elenco di domini malevoli preimpostati.

2. Catena di Infezione e Flusso di Esecuzione

Il malware impiega un'esecuzione in più fasi e una complessa strategia di evasione delle difese, che porta all'esecuzione parallela di due distinti **infostealer**:

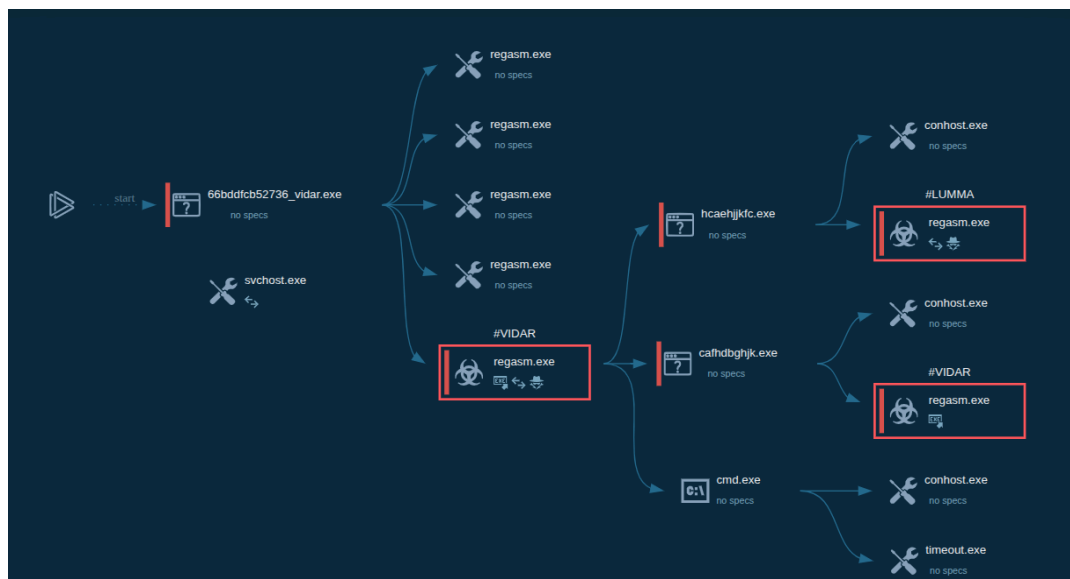


Figura 1: Grafo di esecuzione che mostra il processo iniziale che genera file secondari, i quali a loro volta avviano e iniettano istanze multiple di RegAsm.exe, identificate separatamente come payload Vidar e Lumma.

- **Esecuzione Iniziale e Iniezione:** All'avvio di 66bddfcb52736_vidar.exe, il malware rilascia immediatamente file eseguibili secondari (come **hcaehjjkfc.exe** e **cafhdgbghjk.exe**) e inietta codice malevolo in più istanze del processo legittimo **RegAsm.exe**.
- **Distribuzione del Payload:** I processi RegAsm.exe iniettati contattano server esterni (es. IP 147.45.44.104) tramite **HTTP** per scaricare ulteriori payload malevoli, tra cui **66cb2df8bd684_lawrng.exe** e **66cb2df1d4a01_vakerk.exe**.
- **Evasione delle Difese e Pulizia:** Il malware utilizza **timeout.exe** per ritardare l'esecuzione, una tattica comune per superare i limiti di tempo dell'analisi automatizzata. Successivamente, utilizza il prompt dei comandi di Windows (**cmd.exe**) per avviare comandi di eliminazione (es. /c timeout /t 5 & del /f /q e & del "C:\ProgramData*.dll" & exit) al fine di **rimuovere** le proprie **tracce** e le librerie rilasciate.

3. Funzionalità del Malware e Dati Bersaglio

Le tecniche utilizzate dal malware mappano direttamente numerose tattiche del framework **MITRE ATT&CK**, evidenziando un focus massiccio sul furto di credenziali e sulla scoperta del sistema:

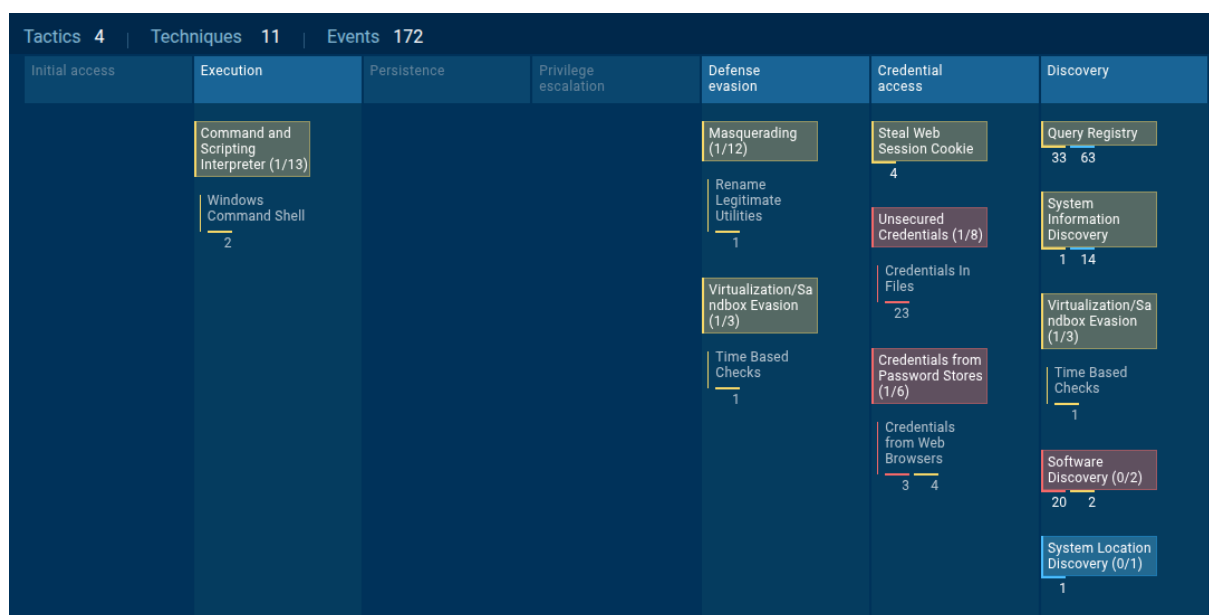


Figura 2: Matrice MITRE ATT&CK che evidenzia le tattiche identificate, confermando l'uso di tecniche di evasione delle difese (Masquerading, Time Based Checks) e un accesso capillare alle credenziali (browser, file, cookie).

I processi RegAsm.exe iniettati eseguono un'ampia ricognizione, differenziandosi per i payload che contengono:

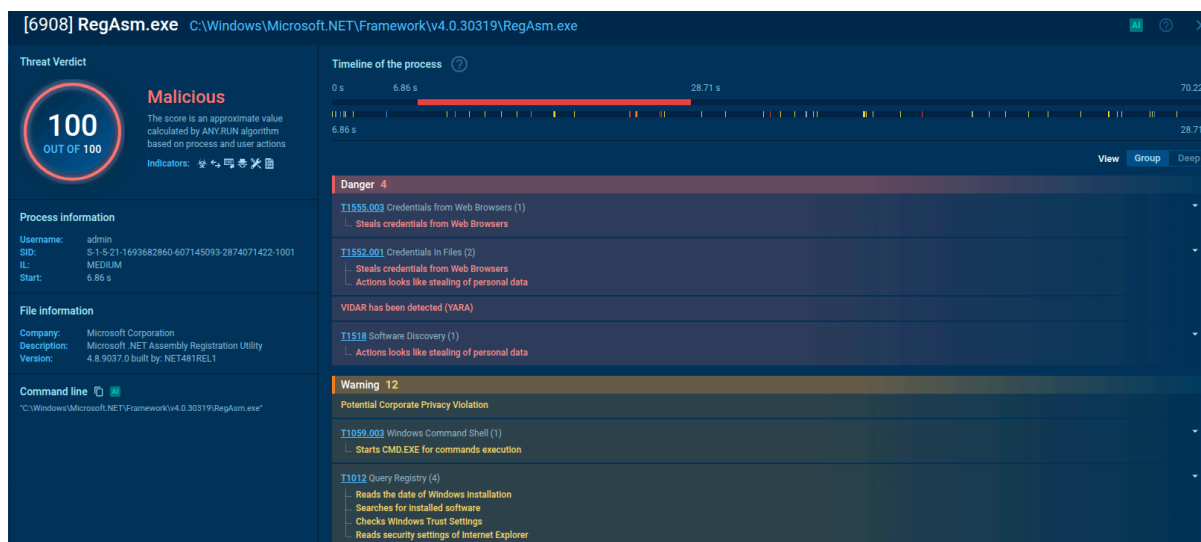


Figura 3: Dettagli del processo RegAsm.exe (PID 6908) rilevato come Vidar tramite firma YARA. Vengono evidenziate le azioni di furto credenziali dai browser e le interrogazioni al registro di Windows.

- **Il payload Vidar (PID 6908):** Interroga attivamente il registro di sistema per scoprire la data di installazione di Windows, le policy di sicurezza di Internet Explorer e il software installato. Si concentra sul database SQLite dei browser (es. Chrome, Firefox, Opera) per esfiltrare cookies.sqlite, formhistory.sqlite, password salvate e carte di credito. Prende inoltre di mira portafogli di criptovalute e file di sessione di client di messaggistica (Telegram, Discord, Steam).

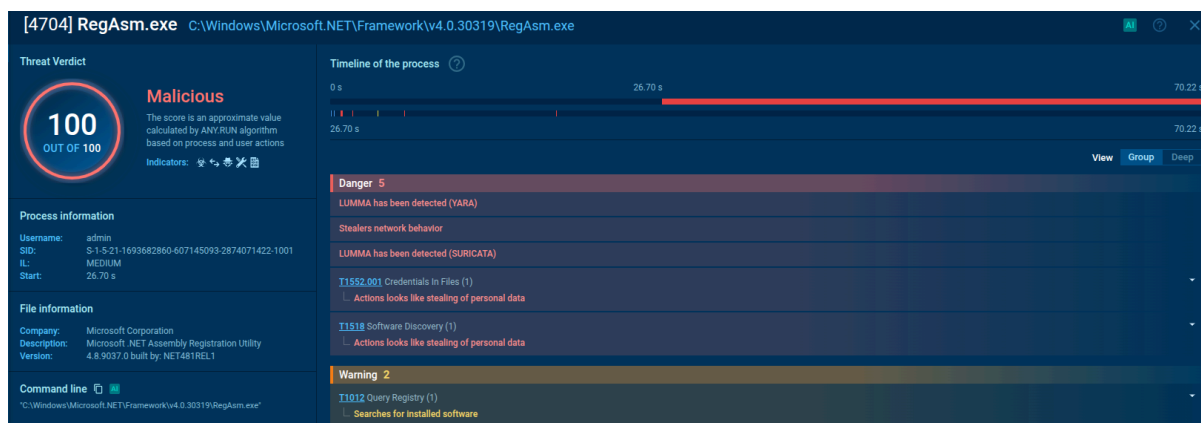


Figura 4: Dettagli del processo RegAsm.exe (PID 4704) rilevato come Lumma tramite firme YARA e rilevamento di rete Suricata, che evidenziano il comportamento tipico di un "Information Stealer".

- **Il payload Lumma (PID 4704):** Si concentra pesantemente sul comportamento di rete da stealer, cercando credenziali all'interno dei file (T1552.001) ed effettuando la scansione del software installato (T1518) per identificare potenziali bersagli sul sistema compromesso.

4. Infrastruttura di Comando e Controllo (C2)

L'infrastruttura di rete rivela l'uso di tecniche di offuscamento (Dead Drop Resolvers) in combinazione con domini standard:

- **Dead Drop Resolver (Vidar):** Il malware contatta profili Telegram (es. <https://t.me/pechOnk>, <https://t.me/jamelwt>) e profili della community di Steam (es. <https://steamcommunity.com/profiles/76561199751190313>). Gli attaccanti utilizzano queste piattaforme per nascondere i veri indirizzi IP dei server C2, rendendo difficile il blocco basato sul semplice filtraggio DNS.
- **Domini C2 Dedicati (Lumma):** Lumma tenta di connettersi a molteplici domini .shop, tra cui [condedqpwqm.shop](#), [stagedchheiqwo.shop](#) e [caffegclasiqwp.shop](#).

5. Indicatori di Compromissione (IOC)

Tipo	Indicatore	Descrizione
SHA256	325396D5FFCA854673089A56C2D0ED99238D48B5E1C3C49E7D027505EA138801	Eseguibile primario (66bddfcb52736_vidar.exe)
MD5	FEDB687ED23F77925835623027F79988	Eseguibile primario (66bddfcb52736_vidar.exe)
Dominio	172.67.215.62	Dominio C2 di Lumma
Indirizzo IP	147.45.44.104	Server di hosting del payload secondario
URL	http://147.45.44.104/prog/66cb2df8bd684_lawrng.exe	URL di download del payload
URL	https://t.me/pechOnk	Meccanismo C2 di Vidar tramite Telegram

SANDBOX 2

Analisi Tecnica URL

<https://click.convertkit-mail2.com/wvuqovqrrwagh50ndddc7hnxdlxxu8/48hvhehr87opx8ux/d3d3Lmluc3RhZ3JhbS5jb20vYXVzc2llbnVyc2VyZWNYdWl0ZXJz>

1. Identificazione del Dominio

- **Dominio:** click.convertkit-mail2.com
 - **Servizio:** Il link è generato da **ConvertKit**, un'infrastruttura di *Email Marketing Automation*.
 - **Funzione:** Viene utilizzato come gateway di tracciamento per monitorare l'interazione dell'utente (click, timestamp, indirizzo IP) prima di indirizzarlo alla destinazione finale.
-

2. Destinazione dell'URL

L'ultima parte dell'URL contiene una stringa codificata in **Base64** che nasconde la destinazione reale:

- **Stringa codificata:**
d3d3Lmluc3RhZ3JhbS5jb20vYXVzc2llbnVyc2VyZWNYdWl0ZXJz
 - **Stringa decodificata:** www.instagram.com/aussienurserecruiters
-

3. Meccanismo di Reindirizzamento

Il link utilizza un reindirizzamento lato server. Dal punto di vista della sicurezza, questo processo può essere riassunto nei seguenti passaggi:

1. **Request:** L'utente invia una richiesta GET al server di ConvertKit.
 2. **Tracking:** Il server registra i dati della vittima/utente.
 3. **Redirect:** Il server risponde con un codice di stato HTTP puntando all'account Instagram decodificato.
-

4. Considerazioni di Security & Forensics

- **Offuscamento:** Sebbene in questo caso l'uso sia legittimo (marketing), la tecnica di nascondere la destinazione finale tramite codifica Base64 è un metodo comune nelle campagne di **Phishing** e nei **Malware Delivery** per eludere i controlli statici dei filtri email.
- **Analisi dei Rischi:** Cliccare sull'URL conferma al mittente che l'account email dell'utente è attivo e "monitorato", aumentando il punteggio di appetibilità per futuri attacchi di ingegneria sociale.